

Backlog Consolidado de Pendências (Cap. 1 → 7)

Capítulo 1 — Introdução, Propósito e Contexto

1. Fronteiras de sistema não formalizadas (diagrama/contratos)

- Problema: Middleware é definido, mas sem **diagrama de contexto** e **contratos de integração** explícitos com o LLM/cliente.
- Gravidade: ● Crítico | Esforço: ● Moderado
- Evidência: Cap. 1 define papéis, mas os contratos aparecem só depois (APIs no complemento) .
- Ação: Inserir diagrama LLM ↔ TER-Kai ↔ Usuário e contratos I/O já refletindo `/api/v1/chat/invoke`, `/api/v1/logs` e `/api/v1/policies`.

2. Dependência de métricas externas sem catálogo

- Problema: Declara “depende de métricas externas”, mas **não lista fontes/formato/validação**.
- Gravidade: ● Moderado | Esforço: ● Moderado
- Evidência: KPIs/V&V usam métricas (PII, tom, etc.), porém catálogo formal não está no Cap. 1; o complemento traz *plugins/telemetria* mais adiante .
- Ação: Tabela de métricas externas (origem, hash de referência, atualização) vinculada ao DED/RAP.

3. Glossário sem versões/schemas canônicos

- Problema: Termos (Kai, MIR, Ω ...) sem **versões/IDs/schemas** na abertura.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: Os **schemas canônicos** (AuditLog/PolicyConfig/Outbox) estão no complemento, não referenciados pelo Cap. 1 .
- Ação: Anexar versões/schemas (prisma/Zod) ao glossário inicial.

4. Premissas não testáveis

- Problema: Premissas de operação não têm **critérios de validação** no Cap. 1 (ficam no Cap. 6).
- Gravidade: ● Moderado | Esforço: ● Moderado

- Evidência: Cap. 6 traz V&V e KPIs (PII 99,9%, FPR≤1%, TSA) sem ligação à premissa do Cap. 1 .
- Ação: Referenciar diretamente os testes V&V/Golden Set desde o Cap. 1.

5. Papéis/RBAC não ancorados no Cap. 1

- Problema: Público-alvo é citado, mas **RBAC/SoD** aparecem formalmente só no complemento (e Cap. 5).
- Gravidade: ● Leve | Esforço: ● Leve
- Evidência: Complemento define RBAC e telas HITL/Review; Cap. 5 cita política de acesso, mas sem SoD explícito .
- Ação: Trazer matriz de papéis para a introdução, apontando para `/api/v1/review-queue`.

Capítulo 2 — Arquitetura Geral e Governança

6. Topologia de implantação ausente

- Problema: Arquitetura lógica L0–L4 sem **topologia física** (serviços, filas, banco).
- Gravidade: ● Crítico | Esforço: ● Moderado
- Evidência: Topologia surge no complemento (Postgres/Redis/Workers) e endpoints REST .
- Ação: Publicar diagrama de implantação com Redis (Outbox), Postgres e TSA Worker.

7. Schemas de troca não formalizados no Cap. 2

- Problema: Cita `metrics_input/kai_packet`, mas **sem schema/versão** no Cap. 2.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: Schemas canônicos (AuditLog, PolicyConfig, TsaOutbox) no complemento (Prisma/Zod) .
- Ação: Tabela de contratos com Zod + checksums.

8. Baseline de políticas (Ω) não publicada

- Problema: Faltam **regras CEL/JSONLogic exemplo** no Cap. 2.
- Gravidade: ● Moderado | Esforço: ● Moderado
- Evidência: CRUD de políticas e `policyHash` estão no complemento; baseline não está no Cap. 2 .
- Ação: Publicar *policy default* (PII → BLOCK, etc.).

9. RBR (Risk Based Routing) não introduzido como estrutura

- Problema: RBR aparece só depois como fluxo (Cap. 4), não como **pilar da arquitetura** no Cap. 2.
- Gravidade: ● Leve | Esforço: ● Leve
- Evidência: A distinção FAST/DEEP está nos enums/schemas (Mode) .
- Ação: Introduzir RBR e Mode (FAST/DEEP) aqui.

10. Ledger sem diagrama de integridade

- Problema: Faltam **hash-chain/Merkle** e diagrama PoP-L.
 - Gravidade: ● Moderado | Esforço: ● Moderado
 - Evidência: Cap. 7 descreve hashing+TSA; encadeamento não normatizado .
 - Ação: Incluir encadeamento/“ponteiro” no DED.
-

Capítulo 3 — Módulos Internos e API (r3.1)

11. Fronteiras de responsabilidade por módulo não mapeadas

- Problema: Falta tabela de **entradas/saídas/erros/logs** por módulo (L0–L4).
- Gravidade: ● Crítico | Esforço: ● Moderado
- Evidência: As transações/Outbox ficam claras no complemento, não no Cap. 3 .
- Ação: Tabela de responsabilidade + erros esperados.

12. Contratos de API internos sem especificação no Cap. 3

- Problema: Objetos citados, mas **endpoints/params** vêm só no complemento.
- Gravidade: ● Crítico | Esforço: ● Leve
- Evidência: `/api/v1/logs` (lista/detalhe), `/review-queue` documentados no complemento .
- Ação: Referenciar oficialmente os endpoints no Cap. 3.

13. Tratamento de falhas/retries não padronizado no Cap. 3

- Problema: Retro tem timeout, mas **fallback/retry/outbox** não estão descritos aqui.
- Gravidade: ● Moderado | Esforço: ● Moderado
- Evidência: Política de retry/backoff e TSA Outbox aparecem em Cap. 5 e complemento .
- Ação: Padronizar retries e estados no texto do Cap. 3.

14. Sanitização/anonimização sem metas

- Problema: “maskPII/redact...” sem **metas de cobertura** no Cap. 3 (meta está no Cap. 6).

- Gravidade: 🟡 Moderado | Esforço: 🟢 Leve
- Evidência: KPI 99,9% PII em Cap. 6 .
- Ação: Referir KPI de PII no Cap. 3.

15. Temporalidade do Ledger (sync vs async) ambígua

- Problema: Cap. 3 não diz se PoP-L é **assíncrono** (é, via Outbox).
- Gravidade: 🟡 Moderado | Esforço: 🟡 Moderado
- Evidência: Outbox/worker TSA no complemento; status pendente/confirmado nos logs .
- Ação: Explicitar assíncrono e estados (queued/processing/confirmed/failed).

Capítulo 4 — Ciclo de Processamento e Fluxos

16. FSM (estados/transições) inexistente

- Problema: Fluxo linear, **sem estados nomeados** (WAITING, REVIEW, RETRO_PENDING...).
- Gravidade: 🔴 Crítico | Esforço: 🟡 Moderado
- Evidência: Estados aparecem indiretamente via enums e filas no complemento, não no Cap. 4 .
- Ação: Publicar FSM operacional completo.

17. RBR sem critérios/limiares numéricos

- Problema: Faltam **limiares** (p.ex., toxicity_index, bias_score) para Fast/Deep/Review.
- Gravidade: 🔴 Crítico | Esforço: 🟡 Moderado
- Evidência: O modo (FAST/DEEP) existe no schema; sem tabela de critérios no Cap. 4 .
- Ação: Tabela de critérios e destino de roteamento.

18. Concorrência/sincronização não documentadas

- Problema: Não há nota sobre **paralelismo, locks e atomicidade** entre módulos/ledger.
- Gravidade: 🟡 Moderado | Esforço: 🟡 Moderado
- Evidência: Transação/Outbox exibidas no complemento .
- Ação: Descrever atomicidade por auditLogId e fila Redis.

19. HITL (pontos, trilha, override) sem fluxo normatizado

- Problema: Faltam **endpoints/etapas/logs** da intervenção humana no Cap. 4.
- Gravidade: 🟡 Moderado | Esforço: 🟢 Leve

- Evidência: Endpoints de revisão/HITL no complemento; Cap. 4 não detalha .
- Ação: Amarrar Cap. 4 à fila HITL com `human_override` no DED.

20. Catálogo de exceções/falhas não publicado

- Problema: Faltam **códigos de erro e ações** por falha crítica (`policy_not_found`, `tsa_fail...`).
 - Gravidade: ● Leve | Esforço: ● Leve
 - Evidência: Retry e estados TSA estão descritos, mas sem catálogo de erros .
 - Ação: Tabela de exceções + resposta padrão.
-

Capítulo 5 — Conformidade, Segurança e Integridade

21. PoP-L sem verificador externo/encadeamento

- Problema: Hash+TSA ok, mas **sem CLI/script de verificação** e **hash-chain/Merkle**.
- Gravidade: ● Crítico | Esforço: ● Moderado
- Evidência: Processo PoP-L completo (hash/TSA), porém sem encadeamento/verificador oficial .
- Ação: Publicar verificador e apontador para registro anterior.

22. Matriz regulatória (requisito → evidência → teste) ausente

- Problema: Há mapeamentos qualitativos, mas **não existe matriz rastreável** por requisito/artefato/teste.
- Gravidade: ● Crítico | Esforço: ● Moderado
- Evidência: Artefatos DED/RAP/V&V existem, falta a matriz no Cap. 5 .

23. Gestão de chaves não detalha KEK/DEK/rotação comprovável

- Problema: Política cita **AES-256-GCM e KMS** e **rotação**, mas sem **provas/fluxo de recripto**.
- Gravidade: ● Moderado | Esforço: ● Moderado
- Evidência: Política de criptografia/rotação no Cap. 5; debug cifrado/“envelope” no complemento .

24. “Produção sem debug” não normatizado no Cap. 5

- Problema: **AuditLogDebug** existe (Bytes cifrados, TTL), porém falta **proibição explícita em produção**.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: Condição RBAC+logging.level no complemento, sem política rígida no Cap. 5 .

25.SLOs de incidentes/alertas mínimos ausentes

- Problema: Retry/backoff descritos; faltam **SLOs/SLAs** (lag Outbox, P95 TSA, P95 Fast).
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: Cap. 5 define retry e fila; KPIs de latência no Cap. 6, mas sem SLO operacional aqui .

26.SoD/dupla aprovação e marcação `human_override` faltando no DED

- Problema: RBAC presente; **SoD e `human_override`** não canonizados no DED.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: HITL/Review-queue têm endpoints; falta o campo no DED/log .

27.Multi-tenancy explicitamente fora do Cap. 5

- Problema: Tenancy/RLS aparecem no complemento; Cap. 5 não **afirma** isolamento.
- Gravidade: ● Leve | Esforço: ● Leve
- Evidência: Campos `tenantId`/RLS no complemento .

Capítulo 6 — Testes, Validação (V&V) e KPIs

28.KPIs sem plano estatístico (N, IC, estratos)

- Problema: Metas fortes (PII 99,9%, FPR≤1%, etc.) sem **método estatístico**.
- Gravidade: ● Crítico | Esforço: ● Moderado
- Evidência: KPIs listados; método não detalhado .

29.Governança incompleta do Golden Set

- Problema: Golden set versionado/registrado no PoP-L, porém sem **cobertura/estratificação/atualização** normatizadas.
- Gravidade: ● Crítico | Esforço: ● Moderado
- Evidência: Criação/registo no PoP-L descritos; governança detalhada ausente .

30.Cargas/soak/concurrency e *circuit breaker* de plugins ausentes no plano

- Problema: Falta **perfil de carga** e cenário de **degradação controlada**.
- Gravidade: ● Moderado | Esforço: ● Moderado
- Evidência: Retry/TSA worker existem; sem testes de carga formais no Cap. 6 .

31.Lacunas de métricas para factual/bias

- Problema: KPIs focam PII/tom; **FN/FP por factual/bias** não estão definidos aqui.

- Gravidade: ● Moderado | Esforço: ● Leve

- Evidência: KPIs/Exemplos V&V atuais .

32.CI/CD sem “gates” e rollback normatizados

- Problema: CI/CD roda V&V; faltam **limiares de reprovação** e **rollforward/rollback** vinculados ao PoP-L.

- Gravidade: ● Moderado | Esforço: ● Leve

- Evidência: Complemento define CI; Cap. 6 não fixa *gates* .

33.Reprodutibilidade parcial (seed, modelo, ambiente)

- Problema: Relatório V&V sem **llm_provider/model/version**, seed, imagem/commit **obrigatórios**.

- Gravidade: ● Moderado | Esforço: ● Leve

- Evidência: Campos existem no schema (AuditLog), não exigidos no relatório .

34.Relatório PDF/A sem SLOs mínimos

- Problema: Relatório é assinado (ótimo), mas **sem metas** (TSA lag, %confirmed, P95 path).

- Gravidade: ● Leve | Esforço: ● Leve

- Evidência: PDF/A PoP-L previsto; SLOs não fixados no Cap. 6 .

Capítulo 7 — Especificações Criptográficas e Algoritmos

35.Verificador externo e encadeamento do PoP-L ausentes

- Problema: Algoritmo PoP-L sem **CLI/verificador** e **hash-chain/Merkle**.

- Gravidade: ● Crítico | Esforço: ● Moderado

- Evidência: Fluxo HASH+TSA detalhado; verificador/chain não .

36.Guardrails do motor Ω (lint/consistência) não exigidos no capítulo

- Problema: Uso de CEL/JSONLogic seguro, mas sem **linter/validação** normatizada.

- Gravidade: ● Moderado | Esforço: ● Leve

- Evidência: PolicyConfig + `policyHash` no complemento; Cap. 7 não exige lint/teste de regras .

37.Backoff sem limites/telemetria mínima

- Problema: Fala em **exponential backoff**, sem **max_retries/budgets/métricas** no Cap. 7.

- Gravidade: ● Moderado | Esforço: ● Leve

- Evidência: No Cap. 5 há parâmetros e fila; Cap. 7 deveria fixar limites mínimos .

38.Suite anti-ReDoS (regex) não padronizada

- Problema: RE2 exigido, mas **sem corpus adversarial/limites** formalizados aqui.
- Gravidade: ● Moderado | Esforço: ● Moderado
- Evidência: Testes de fuzzing citados em Cap. 6; Cap. 7 não os canoniza como requisito de conformidade .

39.SLOs/circuit-breaker de plugins MIR ausentes

- Problema: Telemetria existe; faltam **SLOs por plugin e fail-open/closed** por risco.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: `latency_ms`, `budgetMs/timeout` no complemento; capítulo não fixa SLOs .

40.Procedimento canônico de serialização não formalizado

- Problema: “JSON determinístico” sem **passos canônicos** (ordem de chaves, números, Unicode).
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: Complemento traz `stableStringify/canon` e campos de hash no DED; Cap. 7 não fixa o procedimento .

Novas pendências (drifts e inconsistências detectadas entre artefatos)

41.Inconsistência do enum `TsaStatus`

- Achado: Em trechos do complemento, `TsaStatus = {queued, processing, confirmed, failed}`; em outro artefato, enum/estado aparece como `{pending, confirmed, failed}`.
- Risco: Divergência de estados entre serviços e relatórios (ex.: filtros `?tsa_status=`).
- Gravidade: ● Crítico | Esforço: ● Leve
- Evidência: `queued/processing/confirmed/failed` ; `pending/confirmed/failed` no ARTEFATO 01 ; respostas de API usam “`pending/confirmed`” .
- Ação: Unificar `TsaStatus` em todos os lugares e migrar dados/filters.

42.Tipo do campo `role` em `User` (String vs Enum)

- Achado: Um trecho define `role: String @default("AUDITOR")`; outro define `enum Role { ... }` com `role Role @default(AUDITOR)`.
- Risco: Validação fraca e divergência de serialização/FE.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: `role String; enum Role + role Role`.
- Ação: Padronizar para **Enum Role** e migrar.

43. Unicidade/índices de **PolicyConfig.domain** (único vs não único)

- Achado: Em um local, `domain` é **@unique**; em outro, aparece **sem @unique**.
- Risco: Duplicidade de políticas por domínio; confusão no *policy selection*.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: `domain @unique`; versão sem `@unique` (ARTEFATO).
- Ação: Fixar `@unique` (com versionamento por `version`) ou chave composta (`domain, version`).

44. **TsaOutbox** relacionamento/**onDelete** inconsistente

- Achado: Há definição com **onDelete: Cascade** e outra sem.
- Risco: *Dangling rows* e inconsistências de reprocessamento TSA.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: Com `onDelete: Cascade`; versão sem (definição simplificada).
- Ação: Padronizar `onDelete: Cascade` (e revisar runbook de *replays*).

45. Nomes/estados usados na API vs schema

- Achado: API `/api/v1/logs` retorna `tsa_status: "confirmed"` e usa filtros; estados da enum variam (vide item 41).
- Risco: Inconsistência entre **contrato de API** e **enum**.
- Gravidade: ● Moderado | Esforço: ● Leve
- Evidência: Respostas/filtros de `/api/v1/logs`.
- Ação: Congelar contrato da API e alinhar enums.

Prioridades (Impacto × Esforço)

P0 (corrigir primeiro): 6, 11, 16, 17, 21, 22, 28, 29, 35, 41

P1: 7, 8, 10, 12, 13, 15, 18, 19, 23, 24, 25, 32, 33, 39, 40, 42, 43, 45

P2: 1, 2, 3, 4, 5, 9, 14, 20, 26, 27, 30, 31, 34, 36, 37, 38, 44

Próximos Passos Recomendados

1. Convergência de Schemas/Enums (P0)

- Padronizar **TsaStatus** (uma enum), **Role** como enum, unicidade de **PolicyConfig.domain**, **onDelete: Cascade** nos relacionamentos. (Gerar migração única).
— Evidências:

2. Publicar artefatos de auditoria reproduzíveis (P0)

- **CLI verificador PoP-L** (rebuild DED → SHA3-512 → valida RFC 3161) + **hash-chain/Merkle**.
— Evidências:

3. Formalizar RBR e FSM (P0)

- Tabelar **limiares** (PII/bias/toxicity/trust) → FAST/DEEP/REVIEW/BLOCK; publicar **FSM** com estados/transições.
— Evidências:

4. Plano estatístico dos KPIs + Governança do Golden Set (P0)

- Definir **N/IC/estratos**; revisar **cobertura por classe/idioma**, versionamento e registro no PoP-L; **gates de CI** e rollback.
— Evidências:

5. Normas operacionais Cap. 5/7 (P1)

- “**Produção sem debug**” (óbvio por política), **SoD/dupla aprovação**, **human_override** no DED; **SLOs mínimos** (TSA lag, P95).
— Evidências:
-

Status	Prioridade	Pendência / Problema	Responsável	Descrição e Contexto (Resumo Técnico)
■ DO	TO P0	Verificador externo e hash-chain do PoP-L	Eng + Compliance	Implementar CLI de verificação (RFC 3161 + SHA3-512) e encadeamento Merkle entre registros para rastreabilidade forense.
■ DO	TO P0	Matriz regulatória requisito → evidência → teste	Compliance + QA	Construir tabela traçando cada requisito AI Act/NIST/LGPD ↔ evidência (DED/RAP/V&V).
■ DO	TO P0	KPIs sem plano estatístico (N, IC, estratos)	Data + QA	Definir metodologia estatística para validar metas (PII 99,9%, FPR≤1%).
■ DO	TO P0	Governança do Golden Set	QA + Compliance	Normalizar cobertura, atualização e versionamento no PoP-L.
■ DO	TO P0	Enums/contratos divergentes (TsaStatus, Role, domain, onDelete)	Eng	Unificar definições Prisma/API para evitar falhas e incoerência.
■ DO	TO P0	FSM + RBR sem limiares numéricos	Eng + Data	Criar máquina de estados e tabelar critérios FAST/DEEP/REVIEW/BLOCK.
■ DO	TO P0	Topologia de implantação ausente	SRE	Diagrama (Infra, Redis, Postgres, Workers TSA).
■ DO	TO P0	Políticas Ω baseline não publicadas	Eng + Compliance	Criar JSONLogic/CEL default e lint de regras.

Ordem de execução

1. **P0.6 — Topologia de implantação** → base para rastreabilidade/segurança.
2. **P0.11 — Fronteiras por módulo (L0–L4)** → insumo para FSM/RBR.
3. **P0.16 — FSM operacional** → estados/transições padronizados.
4. **P0.17 — RBR com limiares + baseline Ω** → decisões reproduíveis.
5. **P0.21 — Verificador PoP-L + encadeamento** → prova independente.
6. **P0.22 — Matriz regulatória requisito → evidência → teste** → conformidade objetiva.
7. **P0.28 — Plano estatístico dos KPIs** → validade de V&V.
8. **P0.29 — Governança do Golden Set** → dataset controlado e versionado.

9. **P0.35 — Formalização algorítmica (Cap. 7)** → referência única do PoP-L.

10. **P0.41 — Unificação *TsaStatus*** → migração simples; pode rodar em paralelo ao 1–3.

P0.6 — Topologia de implantação (ENTREGUE)

Diagrama (Mermaid)

flowchart LR

subgraph Client

U[Consumer App/API]

end

U -->|/api/v1/chat/invoke| KAI[L0 Kai]

KAI --> MIR[L1 MIR]

MIR --> OMG[L2 Ω Engine]

OMG -->|ALLOW/REVIEW/BLOCK| RETRO[L3 Retro/Reviser]

subgraph Audit

KAI --> LED[L4 Ledger/PoP-L]

MIR --> LED

OMG --> LED

RETRO --> LED

LED --> PG[(PostgreSQL)]

LED --> R[(Redis Outbox)]

R --> TSAW[TSA Worker]

TSAW --> TSA[(RFC3161 TSA)]

end

Componentes (resumo)

- **L0 Kai:** extração/PII; **L1 MIR:** agregação/plugins; **L2 Ω:** regras (ALLOW/REVIEW/BLOCK); **L3 Retro:** correção/revalidação; **L4 Ledger:** DED/hash/TSA.
- **Infra:** Postgres (dados/DED), Redis (Outbox), TSA Worker (timestamp), KMS (chaves), RBAC (API).
- **Segurança:** TLS interno; *service accounts* por serviço; variáveis de ambiente via KMS; egress apenas TSA.

Ingress/Egress essenciais

- Ingress: /api/v1/chat/invoke, /api/v1/policies, /api/v1/logs, /api/v1/review-queue.
- Egress: TSA (RFC3161) via TSA Worker.
- Observabilidade: métricas p50/p95/p99; lag Outbox; taxa TSA fail.

P0.11 — Fronteiras por módulo (ENTREGUE)

Módulo	Entrada	Saída	Responsabilidade	Erros esperados	Evento de auditoria
L0 Kai	prompt bruto	kai_packet (PII flags/claims)	extração + PII/máscara	regex_fail, timeout	audit_l0
L1 MIR	kai_packet + plugins	metrics_agg	agregação + telemetria	plugin_timeout, plugin_error	audit_l1
L2 Ω	metrics_agg	decisão {ALLOW/REVIEW/BLOCK}	governança	invalid_rule, policy_not_found	audit_l2
L3 Retro	decisão + contexto	revised_output	correção + revalidação	retro_timeout, retro_fail	audit_l3
L4 Ledger	eventos L0–L3	DED + tsa_token	prova imutável	tsa_fail, tsa_queue_overflow	audit_l4

Regras: cada erro tem **ação padrão** (retry/backoff → Outbox; ou escalonamento para REVIEW/HITL).

P0.16 — FSM operacional (ENTREGUE)

Estados canônicos

RECEIVED

L0_DONE

L1_DONE

DECIDED_ALLOW | DECIDED_REVIEW | DECIDED_BLOCK

RETRO_PENDING | RETRO_DONE

LEDGER_QUEUED | TSA_PROCESSING | TSA_CONFIRMED | TSA_FAILED

FAILED

Transições-chave

- RECEIVED -> L0_DONE -> L1_DONE -> DECIDED_*
- DECIDED_REVIEW -> RETRO_PENDING -> RETRO_DONE -> LEDGER_QUEUED
- LEDGER_QUEUED -> TSA_PROCESSING -> TSA_CONFIRMED | TSA_FAILED

Mapeamento em DB

- `audit_log.state`: armazena estado atual (enum).
- `audit_log.tsa_status`: **QUEUED|PROCESSING|CONFIRMED|FAILED** (ver P0.41).
- `audit_log.human_override`: bool (false default; true quando HITL interveio).
- `audit_log.policy_hash`, `payload_hash_sha3_512`, `tsa_token`.

P0.17 — RBR com limiares + baseline Ω (ENTREGUE)

Tabela de critérios (minimais, ajustáveis via política)

Sinal	Limite	Ação	Caminho
<code>pii_detected==true</code>	—	BLOCK	Deep + Retro
<code>toxicity_index</code>	<code>> 0.70</code>	REVIEW	Deep
<code>bias_score</code>	<code>> 0.60</code>	REVIEW	Deep
<code>trust_score</code>	<code>< 0.30</code>	BLOCK	Deep
<code>factual_risk</code>	<code>> 0.50</code>	REVIEW	Deep

Baseline Ω (JSONLogic – exemplo)

```
{ "if": [ { "var": "pii_detected" }, "BLOCK",
  { "if": [ { ">": [ { "var": "toxicity_index" }, 0.70 ] }, "REVIEW",
    { "if": [ { ">": [ { "var": "bias_score" }, 0.60 ] }, "REVIEW",
      { "if": [ { "<": [ { "var": "trust_score" }, 0.30 ] }, "BLOCK", "ALLOW" ]
    } ] ] ]
  } ] ] }
```

CEL equivalente (esqueleto):

```
pii_detected ? "BLOCK" :
toxicity_index > 0.70 ? "REVIEW" :
bias_score > 0.60 ? "REVIEW" :
trust_score < 0.30 ? "BLOCK" : "ALLOW"
```

Observação: valores são **parâmetros de política** (não hardcoded). Versionar por `policyHash`.

P0.21 — Verificador PoP-L + encadeamento (ENTREGUE)

Extensão do DED (campos)

```
{
  "payload_hash_sha3_512": "hex",
  "tsa_token": "base64-rfc3161",
  "prev_payload_hash": "hex"      // hash-chain (ou MerkleRoot em janelas)
```

}

CLI – especificação

- **Uso:** `popl verify <ded.json> [--tsa-ca <pem>] [--chain <true|false>]`
- **Saída:** OK (0) | FAIL_HASH (2) | FAIL_TSA (3) | FAIL_CHAIN (4)
- **Passos:**
 1. Serializar canonicamente o DED (ver P0.35).
 2. Calcular SHA3-512 e comparar com `payload_hash_sha3_512`.
 3. Validar `tsa_token` RFC-3161 (assinatura + carimbo de tempo).
 4. Se `prev_payload_hash` presente: checar encadeamento (ou validar Merkle root).

Pseudocódigo

```
ded := load_json(path)
canon := stable_stringify(ded_without(["tsa_token"]))
if sha3_512(canon) != ded.payload_hash_sha3_512: exit(2)
if !verify_rfc3161(ded.tsa_token): exit(3)
if ded.prev_payload_hash && ded.prev_payload_hash != load_prev_hash(): exit(4)
exit(0)
```

P0.22 — Matriz regulatória requisito → evidência → teste (ENTREGUE)

Template (MD/CSV)

Requisito	Norma	Feature	Evidência (campo/endpoint)	Caso V&V (ID)	Artefato
Logging auditável	AI Act Art.17	Ledger/ PoP-L	<code>payload_hash_sha3_512, /api/v1/logs/:id</code>	GS-LOG-001	PDF/A DED
Human oversight	AI Act Art.14	HITL/ Review	<code>human_override, /api/v1/review-queue</code>	GS-HITL-002	RAP
Privacy by design	LGPD	maskPII	<code>pii_flags, debug_disabled(prod)</code>	GS-PII-003	Rel. V&V
Risk mgmt	NIST AI RMF	RBR/Ω	<code>decision, policyHash</code>	GS-RBR-004	Rel. V&V

— **Ação:** preencher com todos os controles que já constam nos documentos e linkar IDs de testes (ver P0.29).

P0.28 — Plano estatístico dos KPIs (ENTREGUE)

KPIs e método

- **PII bloqueada** $\geq 99,9\%$ (binomial; IC 95%; N mínimo por idioma/domínio).
- **FPR** $\leq 1\%$ (binomial; IC 95%; estratificar por classe).
- **P95 Fast Path** $< 800\text{ ms}$ (percentis; $N \geq 1.000$ amostras/execução).
- **$>80\%$ correções automáticas** (proporção; IC 95%).

CrITÉrios de aceitação (exemplo)

- reprova se **PII** $< 99,9\%$ em qualquer estrato (IC não cobre meta).
- reprova se **FPR** $> 1\%$ em qualquer estrato.
- reprova se **P95 Fast** $> 800\text{ ms}$.
- reportar também P99 por transparência (não bloqueante).

Relatório V&V deve conter

- N, IC e estratos por KPI; versão do modelo; seed; commit; *environment hash*.

P0.29 — Governança do Golden Set (ENTREGUE)

Manifesto (JSON)

```
{
  "version": "gs-1.0.0",
  "classes": ["PII", "TONE", "FACTUAL", "BIAS", "ADVERSARIAL"],
  "languages": ["pt", "en", "es"],
  "stratification": {"domain": ["legal", "finance", "general"]},
  "min_per_stratum": 200,
  "seed": 42,
  "update_policy": "quarterly",
  "register_in_popl": true
}
```

Processo

- **Criação/Atualização:** curadoria Compliance/QA; hash do arquivo → PoP-L.
- **Uso no CI:** *gate* automático quando meta por estrato não atingida.
- **Challenge set:** adicionar quando surgirem novos vetores (ataques/adversarial).

P0.35 — Formalização algorítmica (Cap. 7) (ENTREGUE)

Procedimento canônico (a incluir no cap. 7)

1. **Normalização Unicode** (NFC).
2. **Ordenação de chaves** (lexicográfica).
3. **Precisão numérica** (p.ex. 6 casas fixas quando aplicável).
4. **stableStringify** → bytes → **SHA3-512**.
5. **RFC-3161**: gerar/validar tsa_token.
6. **Encadeamento**: prev_payload_hash (ou Merkle root).
7. **Exit codes** para verificador (vide P0.21).

Pseudocódigo de serialização

```
canon = stable_stringify(normalize_nfc(sort_keys(strip_debug(ded))))
hash = sha3_512(canon)
```

P0.41 — Unificação TsaStatus (ENTREGUE)

Enum final (sugerida)

QUEUED | PROCESSING | CONFIRMED | FAILED

Migração Prisma (diff ilustrativo)

```
-- 1) criar enum nova
CREATE TYPE "TsaStatusNew" AS ENUM ('QUEUED', 'PROCESSING', 'CONFIRMED', 'FAILED');
```



```
-- 2) alterar coluna
ALTER TABLE "AuditLog"
  ALTER COLUMN "tsa_status" TYPE "TsaStatusNew" USING
    CASE "tsa_status"
      WHEN 'pending' THEN 'QUEUED'
      WHEN 'queued' THEN 'QUEUED'
      WHEN 'processing' THEN 'PROCESSING'
      WHEN 'confirmed' THEN 'CONFIRMED'
      WHEN 'failed' THEN 'FAILED'
    END::"TsaStatusNew";
```



```
-- 3) (opcional) remover enum antiga e renomear
```

Back-compat API

- Aceitar filtros `pending` mapeados para `QUEUED` por 1 ciclo de versão.
- Atualizar FE e relatórios; alertas para valores fora da enum.

Encerramento dos P0

Com os artefatos acima, os **P0** ficam resolvidos do ponto de vista de especificação, contratos e governança.